Modélisation Mathématique du Risque et Gouvernance DevSecOps

Modèle d'Évaluation TruRisk Étendu - Projet CyProtect

Documentation d'Architecture

29 août 2026

Résumé

Ce document formalise les équations mathématiques et la logique métier utilisées pour l'évaluation dynamique des risques (Asset Risk Score), la gestion des délais de remédiation (SLA) et la mesure de la dette opérationnelle (MTTR) au sein de la plateforme DevSecOps.

1 Modélisation de l'Asset Risk Score (ARS)

L'Asset Risk Score (ARS) permet d'évaluer le risque réel d'un actif en croisant l'impact métier, la probabilité d'exploitation intrinsèque (Qualys QDS), la topologie réseau, et les contrôles compensatoires issus de la CMDB.

1.1 L'Équation Fondamentale

Le calcul de l'ARS est défini par la formule suivante :

$$ARS = ACS \times \left(\sum_{i \in \{c,h,m,l\}} w_i \cdot \text{Avg}(QDS_i) \right) \times I_{External} \times M_{Controls} \tag{1}$$

Où :

— ACS (Asset Criticality Score) : Valeur de 1 à 5 définissant l'impact métier de l'actif.
— w_i : Poids logarithmiques appliqués aux sévérités (Critique $w_c = 1.0$, Élevé $w_h = 0.2$, Moyen $w_m = 0.05$, Faible $w_l = 0.01$).
— $Avg(QDS_i)$: Moyenne des scores de vulnérabilités pour une sévérité donnée.

1.2 Les Facteurs de Modulation (Multiplicateurs)

Le score de base est modulé par l'exposition réseau ($I_{External}$) et les mesures défensives existantes ($M_{Controls}$).

$$M_{Controls} = M_{SOC} \times M_{AV} \times M_{Patch} \tag{2}$$

Valeurs de référence des coefficients :

2 Gouvernance et Service Level Agreement (SLA)

Les actifs sont segmentés en 5 classes de risque (de Green à Black) basées sur le score ARS final. Les délais de remédiation (SLA) sont strictement définis par ces classes.

Attribut	Source	Condition	Valeur
$I_{External}$	Qualys (QID 45004)	Si exposé sur Internet	1.2
M_{SOC}	CMDB	Si l'actif est monitoré (SIEM)	0.8
M_{AV}	CMDB	Si présence d'un EDR/Antivirus	0.9
M_{Patch}	CMDB	Si exclusion du cycle de patch	1.3

TABLE 1 – Matrice des multiplicateurs de risque résiduel

Classe d'Actif	Seuil ARS	SLA Exigé	Couleur
Black	$ARS \geq 700$	2 Jours	**Noir**
Red	$600 \leq ARS < 700$	7 Jours	**Rouge**
Orange	$400 \leq ARS < 600$	15 Jours	**Orange**
Yellow	$200 \leq ARS < 400$	30 Jours	**Jaune**
Green	$ARS < 200$	90 Jours	**Vert**

TABLE 2 – Matrice dynamique des SLA de remédiation

3 Gestion des Exceptions (Risk Acceptance)

Dans le contexte des environnements de production, certains actifs ne peuvent être mis à jour dans les délais impartis pour des raisons de disponibilité métier critique (Availability) ou d'incompatibilité logicielle (Legacy). Ces actifs sont identifiés dans la CMDB par l'attribut booléen `Exception`.

L'activation de ce flag (`Exception = yes`) n'altère pas l'Asset Risk Score (ARS), car le risque technique physique demeure intact. Cependant, il modifie profondément la gouvernance opérationnelle.

3.1 Impact sur les SLA

Lorsqu'un actif est sous exception, les compteurs de péremption SLA sont suspendus. L'actif échappe à la matrice de violation standard pour basculer dans un statut de **Risque Accepté**.

$$\text{Statut SLA} = \begin{cases} \texttt{ACCEPTED_RISK}, & \text{si } Exception = \text{yes} \\ \text{Évaluation standard (Matrice)}, & \text{si } Exception = \text{no} \end{cases} \tag{3}$$

3.2 Impact sur la Mesure de Performance (MTTR)

Afin de ne pas pénaliser injustement les équipes opérationnelles pour des blocages décidés par le management métier, tout actif sous exception est exclu du périmètre de calcul du MTTR. L'équation du $MTTR_w$ est ainsi conditionnée :

$$MTTR_w = \frac{w_b \sum (TTR_{black} \mid \text{Exc.} = \text{no}) + \dots}{w_b \cdot (C_{black} \mid \text{Exc.} = \text{no}) + \dots} \tag{4}$$

Les risques acceptés feront l'objet d'une revue trimestrielle ou semestrielle dédiée lors des comités de sécurité, afin de vérifier si l'exception métier est toujours justifiée.

4 Mesure de la Performance : Le MTTR Pondéré

Pour mesurer l'efficacité d'une équipe de remédiation sans altérer les exigences absolues du SLA, nous utilisons le Temps Moyen de Remédiation Pondéré ($MTTR_w$).

$$MTTR_w = \frac{w_b \sum TTR_{black} + w_r \sum TTR_{red} + \dots}{w_b \cdot C_{black} + w_r \cdot C_{red} + \dots} \tag{5}$$

Où :
— TTR : Temps de résolution réel (en jours) pour chaque faille corrigée.
— C : Nombre total de vulnérabilités corrigées dans une classe donnée.
— w : Poids accordé à la classe pour le calcul de la performance (ex : $w_b = 10$ pour Black, $w_r = 5$ pour Red).

4.1 Indice de Dette Opérationnelle et Pénalité Globale

Si le $MTTR_w$ d'une équipe dépasse chroniquement les seuils acceptables, un facteur pénalisant (I_{Ops}) peut être appliqué à l'Enterprise Risk Score (ERS) pour refléter l'impact du retard organisationnel sur la posture de sécurité globale de l'entreprise

5 Agrégation Globale : L'Enterprise Risk Score (ERS)

Pour le pilotage stratégique, l'Asset Risk Score (ARS) individuel est agrégé en un indicateur unique représentant la posture de sécurité globale du système d'information : l'Enterprise Risk Score (ERS).

Cette métrique lisse les fluctuations quantitatives du parc (ajout ou suppression de serveurs) en utilisant une moyenne, tout en pénalisant mathématiquement l'organisation si ses processus de remédiation sont défaillants.

5.1 L'Équation de l'ERS

L'ERS est défini comme la moyenne des risques techniques du parc, modulée par un facteur de performance opérationnelle global ($Global_I_{Ops}$) :

$$ERS = \left(\frac{1}{N} \sum_{i=1}^{N} ARS_i \right) \times Global_I_{Ops} \tag{6}$$

Où :
— N : Le nombre total d'actifs scannés et actifs sur le réseau.
— ARS_i : L'Asset Risk Score de l'actif i.

5.2 Le Facteur Opérationnel Global ($Global_I_{Ops}$)

Le facteur $Global_I_{Ops}$ est une fonction de pénalité (malus) qui se déclenche lorsque le Temps Moyen de Remédiation ($MTTR_w$) de l'entreprise dépasse les cibles de conformité (SLA). Il s'agit d'une fonction définie par morceaux :

$$Global_I_{Ops} = \begin{cases} 1.0, & \text{si } MTTR_{global} \leq SLA_{cible} \\ 1.15, & \text{si } SLA_{cible} < MTTR_{global} \leq (SLA_{cible} \times 1.5) \\ 1.30, & \text{si } MTTR_{global} > (SLA_{cible} \times 1.5) \end{cases} \tag{7}$$

Exemple d'interprétation : Si la moyenne technique des serveurs est de 400 (Classe Orange), mais que le département IT met systématiquement deux fois plus de temps que prévu pour patcher, l'ERS montera à $400 \times 1.30 = 520$. Le risque affiché à la direction est aggravé de 30% pour refléter la paralysie opérationnelle, poussant ainsi l'entreprise vers une zone de danger (Classe Orange vers Red).